CS 546
Computer System Security

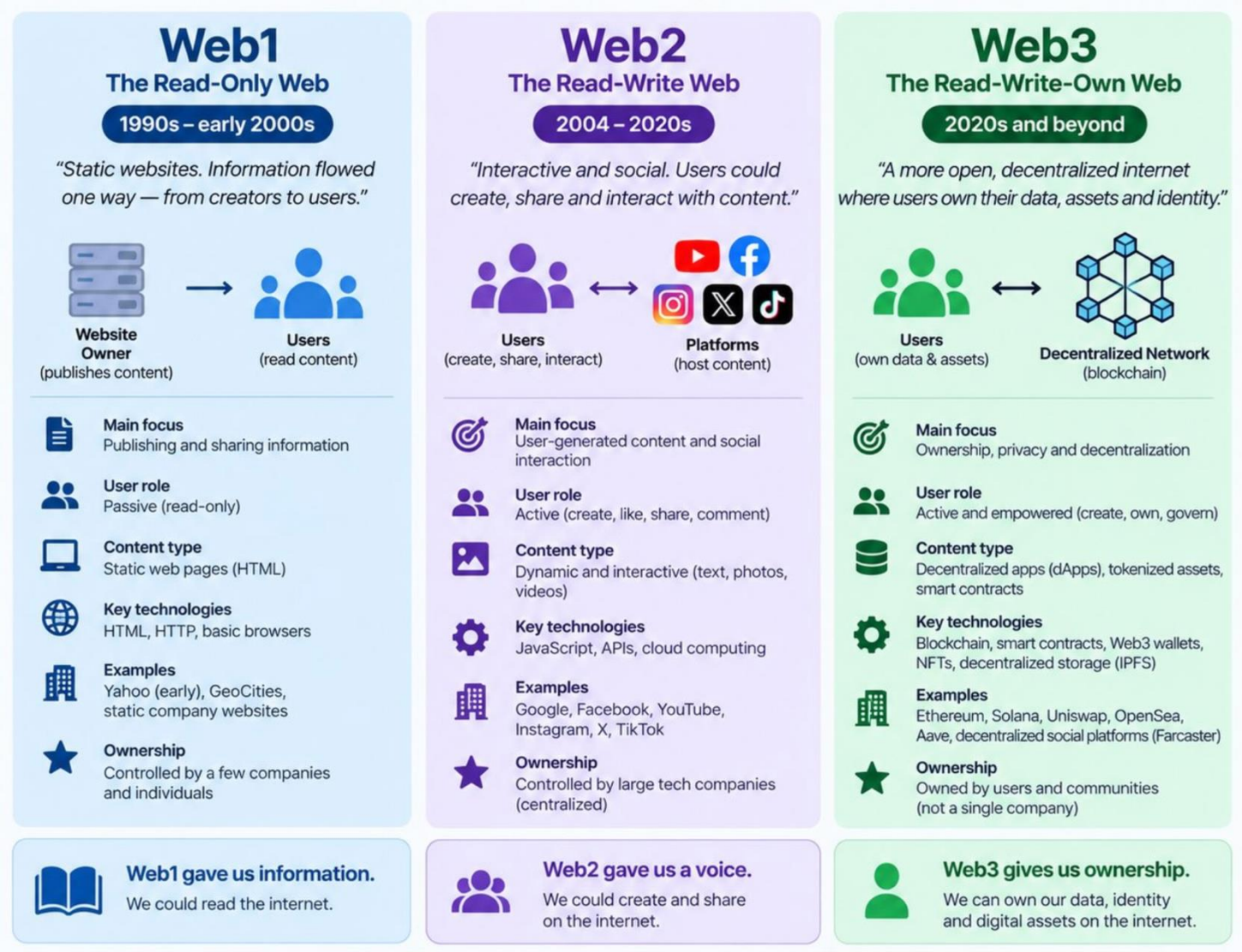
Lecture 8.2: Web3 Applications and Security

Instructor: Aarushi Goel

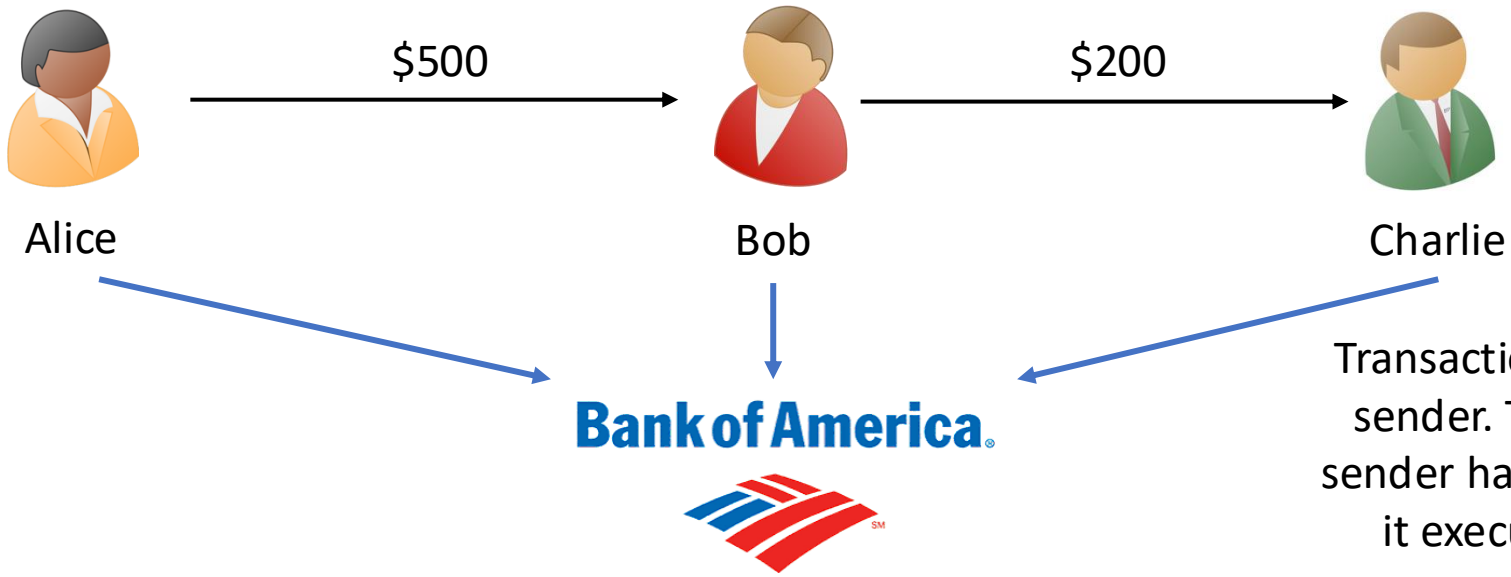
Fall 2026

Evolution of the Internet

(Web1 vs Web2 vs Web 3)

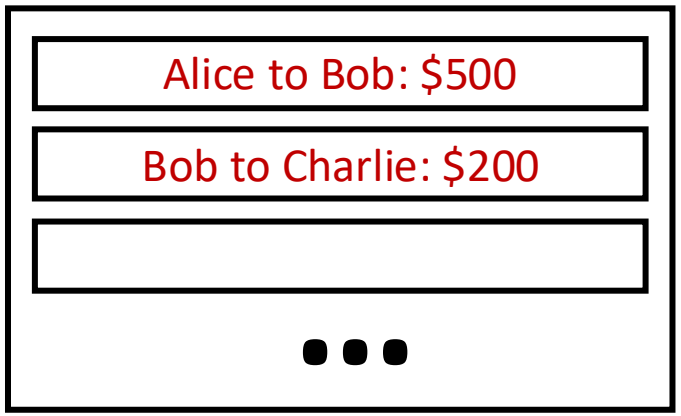


Transactions via Centralized Banks



Transactions are initiated by the sender. The bank checks if the sender has enough balance. If so, it executes the transaction.

The bank here essentially acts as a trusted party acting as a mediator, who maintains a private ledger of all transactions.



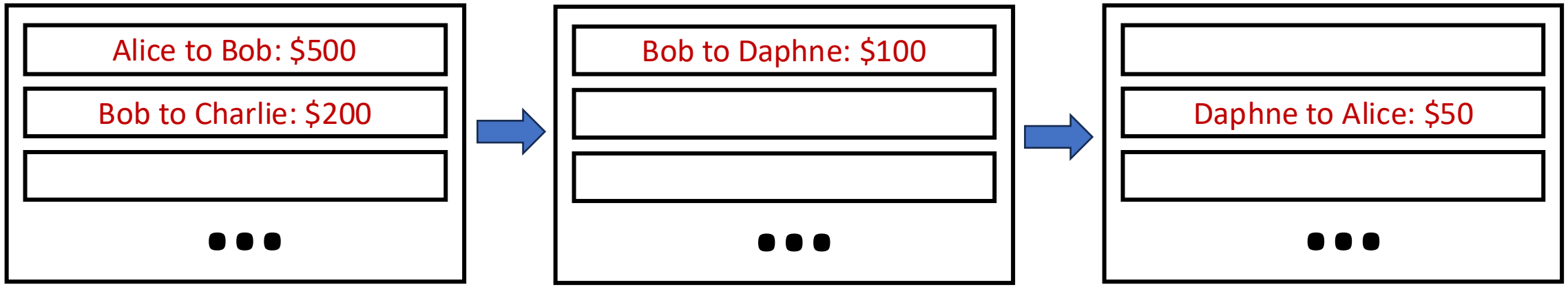
Transactions via Centralized Banks

Problems with this framework:

- Single point of failure: If the bank's systems experience an outage or cyberattack, users may temporarily lose access to their accounts and payment services.
- Dependence on a trusted intermediary: Users rely on the bank to maintain accurate records, prevent unauthorized modifications, and execute transactions correctly.
- Censorship and restricted access: A bank can freeze accounts, reject transactions, or restrict access to services, sometimes for legitimate regulatory or fraud-prevention reasons.
- Privacy concerns: Banks can observe users' transactions, balances, and financial activity. A compromise may expose sensitive financial information.
- Transaction costs and delays: Payments, particularly international transfers, may involve multiple intermediaries, fees, and settlement delays.

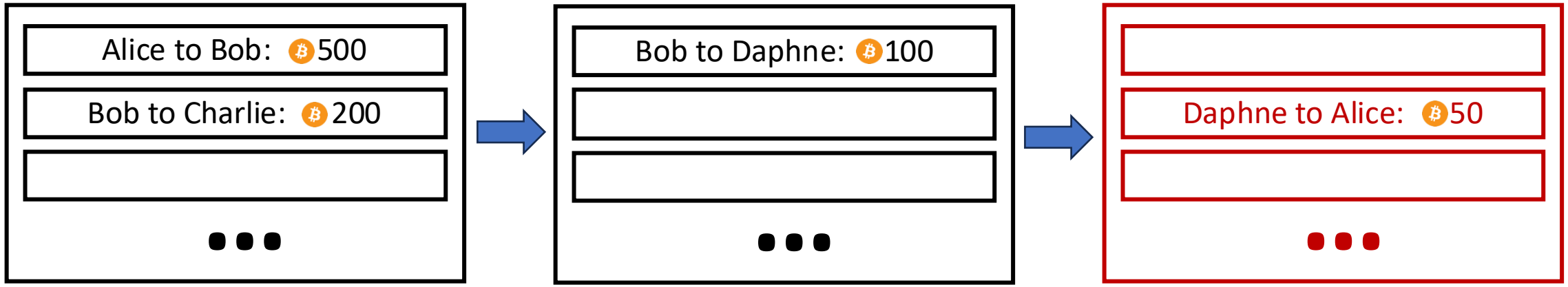
Blockchains

- Blockchain replaces the single trusted ledger operator with a replicated ledger maintained by multiple participants who use a consensus protocol to agree on valid transactions.
- Rather than trusting one bank to update balances correctly, participants can independently verify transactions according to publicly specified rules.



- A blockchain is an ordered list of transactions organized into blocks, where each block contains a batch of transactions. The blocks are cryptographically linked together using hashes, forming a chain that makes modifications to past transactions detectable.
- Popular Examples: Bitcoin, Ethereum, Zcash, Hyperledger, etc.

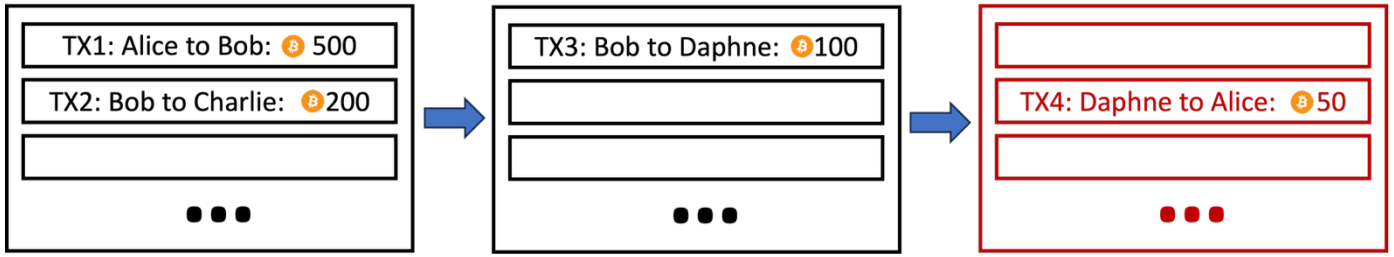
Case Study: Bitcoin



- The public ledger can be viewed and verified by everyone. It is maintained by miners in a distributed way.
- Suppose Daphne wants to send ₿50 to Alice:
  1. Daphne broadcasts this to the entire network.
  2. The miners collect all transactions in the network: Verify the transaction and check whether Daphne has enough balance in her account. If so, add the transaction to the blockchain.

Case Study: Bitcoin
(What is a transaction?)

- Each transaction is a software instruction to be executed by nodes. Each transaction spends old coins and generates new coins.
- Alice, Bob, Charlie, Daphne all sample a signing-verification key pair corresponding to a digital signature scheme.
  - Alice: (sk_A, vk_A)
  - Bob: (sk_B, vk_B)
  - Charlie: (sk_C, vk_C)
  - Daphne: (sk_D, vk_D)
- When Daphne sends 50 bitcoins to Alice, she references the outputs of previous transactions that she wishes to spend. She then constructs a new transaction containing these references, the amount to be transferred, and Alice's verification key. Finally, Daphne uses her secret signing key to digitally sign the transaction, thereby authorizing the transfer.



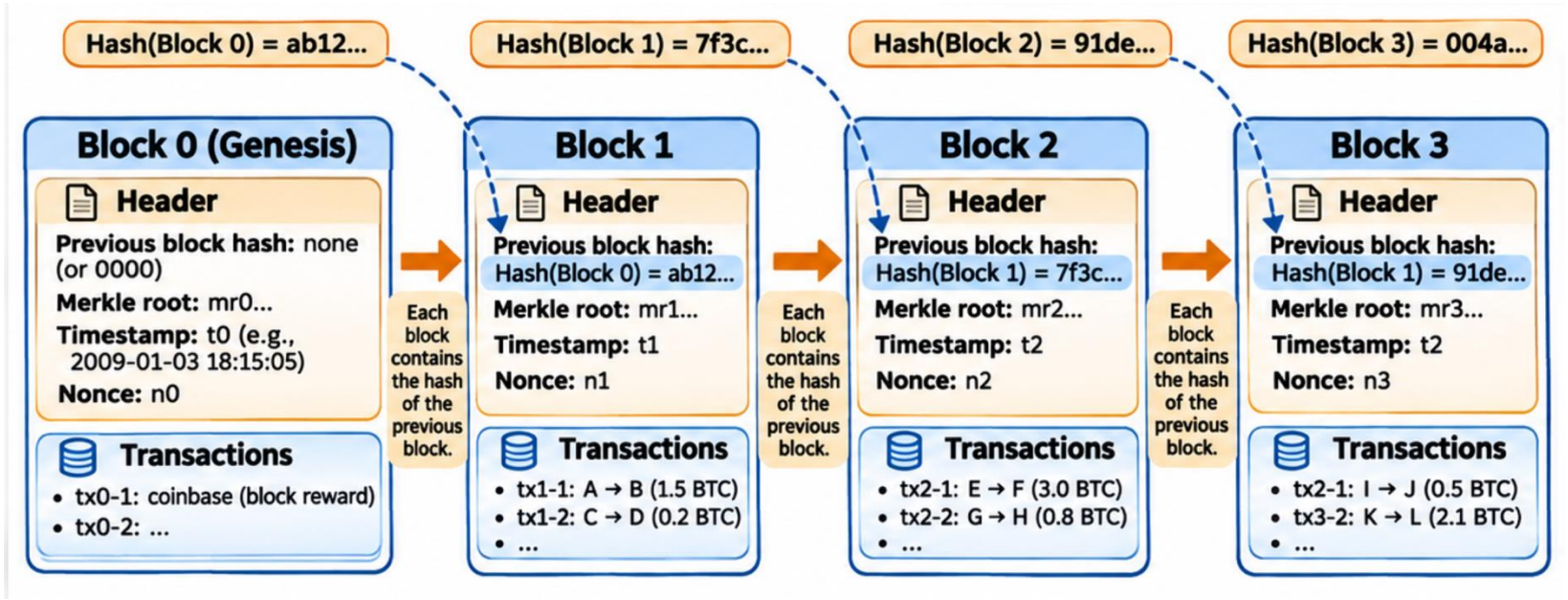
- Transaction TX4 will generate two coins:
  - Coin 1: is of the form: $m_1 = (TX3, 50, vk_A),\ \sigma_1 = Sign(sk_D, m_1)$
  - Coin 2: is of the form: $m_2 = (TX3, 50, vk_D),\ \sigma_2 = Sign(sk_D, m_2)$

Case Study: Bitcoin
(What is a transaction?)



- The Bitcoin network verifies:
  - Signature is valid
  - Input transaction/coin is unspent
  - Transaction format and rules are valid.
- If the transaction is valid, it can be included in a new block. Once confirmed, the previously referenced outputs are considered spent, and new coins are created:
  - Alice's output: 50 BTC, which Alice can spend using her private key.
  - Daphne's change output: Any remaining bitcoins, minus transaction fees, returned to Daphne.
- There are two types of participants in a bitcoin network:
  - Full nodes: Computers in the Bitcoin network that store and independently verify the blockchain and its transactions. Anyone can run a full node.
  - Miners: Participants who collect valid transactions into new blocks and compete to solve computational puzzles (Proof of Work) to add these blocks to the blockchain. Successful miners receive bitcoin rewards.

Case Study: Bitcoin (Miners)



Bitcoin Blockchain

Image generated by ChatGPT

Case Study: Bitcoin (Miners)



Proof of Work (PoW) is the consensus mechanism used by Bitcoin to decide who can propose the next block in the blockchain. It requires miners to solve a computationally expensive puzzle, making it difficult for an attacker to rewrite the blockchain's history.

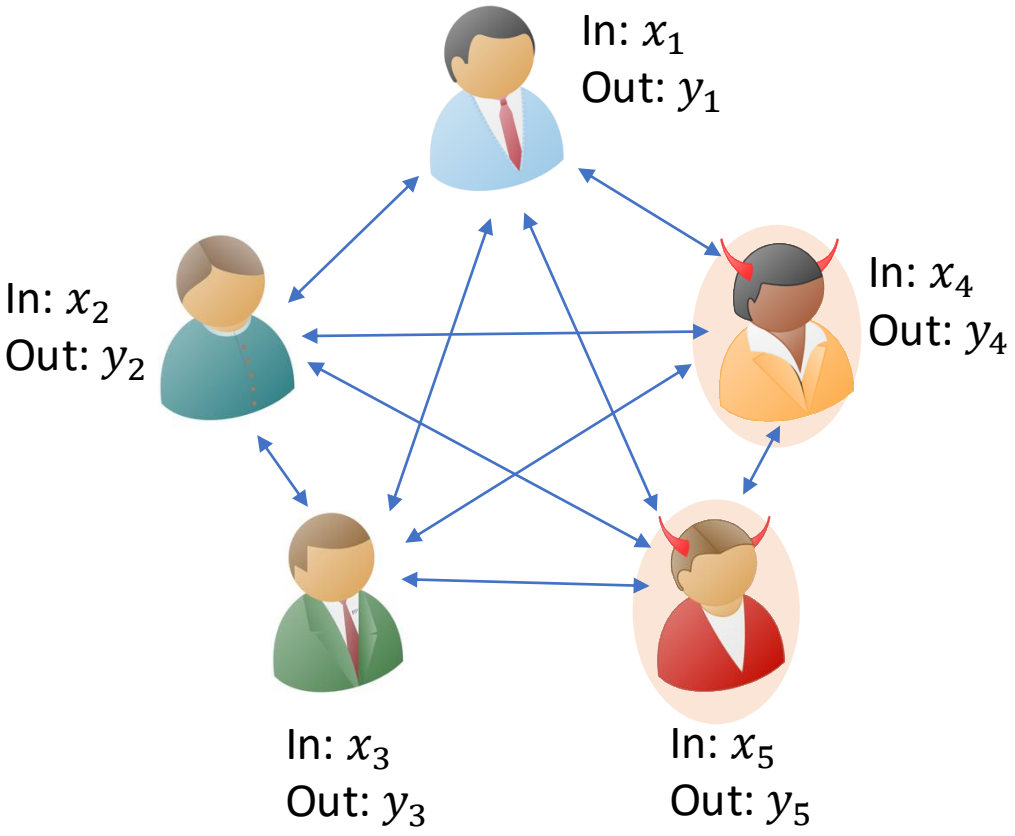
Suppose a miner wants to add a new block containing several Bitcoin transactions:

1. Create a candidate block: The miner collects valid transactions and constructs a block containing the previous block's hash, a Merkle root, a timestamp, and a nonce.
2. Solve a computational puzzle: The miner must find a nonce (and can vary other permitted block data) such that the block header's hash is smaller than a difficulty target T:

$$\text{Hash}(\text{Block Header}) < T$$

3. Try many possibilities: Since cryptographic hash functions behave unpredictably, the miner repeatedly changes the nonce and computes the hash until it finds a valid result.
4. Broadcast the block: Once a miner finds a valid hash, it broadcasts the block to other nodes in the network.
5. Verify and accept: Full nodes verify the proof of work and all other block validity rules.

Consensus/Byzantine Agreement



Agreement $y_1 = y_2 = y_3$

Validity

If: $x_1 = x_2 = x_3$,
Then: $y_1 = y_2 = y_3 = x_1$

If only at most n/3 of the nodes are corrupt and colluding, it is possible to reach consensus.

Case Study: Bitcoin
(Longest Chain Rule)

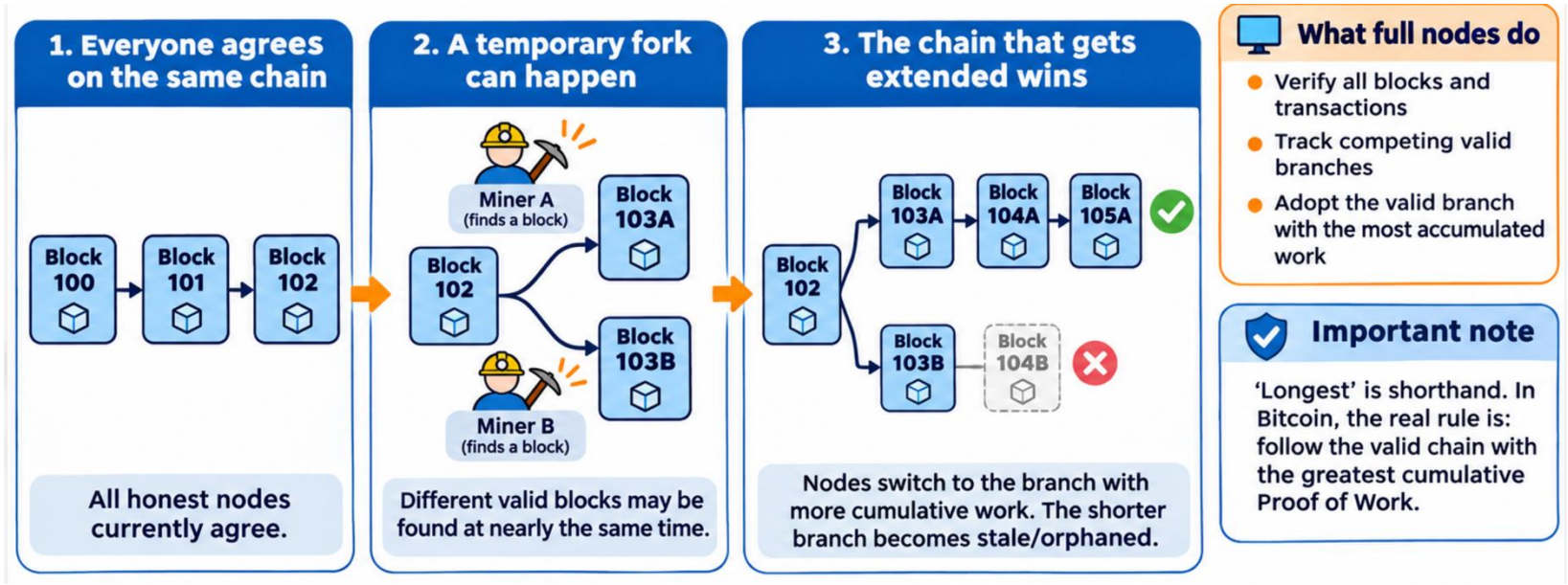


Image generated by ChatGPT

Bitcoin: Security Concerns
(Privacy Leakage)

- Bitcoin transactions are publicly visible. Analyzing transaction histories can reveal relationships between addresses and potentially identify users.



- Zcash is another popular blockchain that supports shielded transactions, which hide the sender's address, recipient's address, and transaction amount from public observers.
- The main challenge they address is how to verify that a transaction is valid when it cannot see the coins being spent or the amount transferred.
- Zcash solves this using cryptographic commitments and zero-knowledge proofs.

Bitcoin: Security Concerns
(Double-Spending Attacks)

- Suppose Alice has 1 BTC and wants to cheat Bob. Alice broadcasts a payment to Bob while simultaneously also creates a conflicting payment to herself. If Bob delivers goods before his transaction is sufficiently confirmed. Alice attempts to get the conflicting transaction accepted instead, so Bob loses his payment.
- Defense: Bitcoin prevents double-spending using two mechanisms:
  - Transaction validation: Nodes check that the bitcoins being spent have not already been spent in the blockchain history they are validating. However, different nodes may temporarily see different conflicting transactions before either is confirmed. This is why transaction validation alone is insufficient.
  - Proof-of-Work consensus: Nodes agree on an accepted blockchain history via consensus, preventing conflicting transactions from both being permanently accepted.
- Bob should wait for confirmations. However, even after Bob's transaction appears in a block, that block could be replaced during a blockchain reorganization. Six confirmations substantially reduce the risk under normal assumptions, but do not provide an absolute guarantee.

Confirmations	Security interpretation
0	Transaction is unconfirmed; a conflicting transaction might be confirmed instead
1	Transaction is included in a block, but that block might be replaced
3	Reversing the transaction generally requires more work
6	Common confirmation threshold for higher-value Bitcoin payments

Bitcoin: Security Concerns
(Mining Centralization or 51% Attack)



- A 51% attack occurs when an attacker controls more than 50% of the total mining computational power (hash rate) in a Proof-of-Work blockchain such as Bitcoin. In this case, the attacker can:
  - Reverse their own previously confirmed transactions (double-spending).
  - Prevent certain transactions from being confirmed (censorship).
  - Temporarily disrupt transaction confirmations and reorganize blocks
- However, the attacker cannot forge another user's signatures, steal their coins without authorization, or create invalid bitcoins. Honest full nodes continue enforcing transaction validity rules.
- Concentration of mining power among a few mining pools also creates similar risks of transaction censorship and coordinated attacks.
- Bitcoin's security assumes that a majority of mining power follows the protocol honestly. Proof of Work makes attacks expensive, but cannot prevent a sufficiently powerful adversary from reorganizing transactions or censoring payments. Mining decentralization is therefore a crucial security assumption, rather than a property guaranteed by Bitcoin's protocol.

Bitcoin: Security Concerns
(Private-Key Theft)



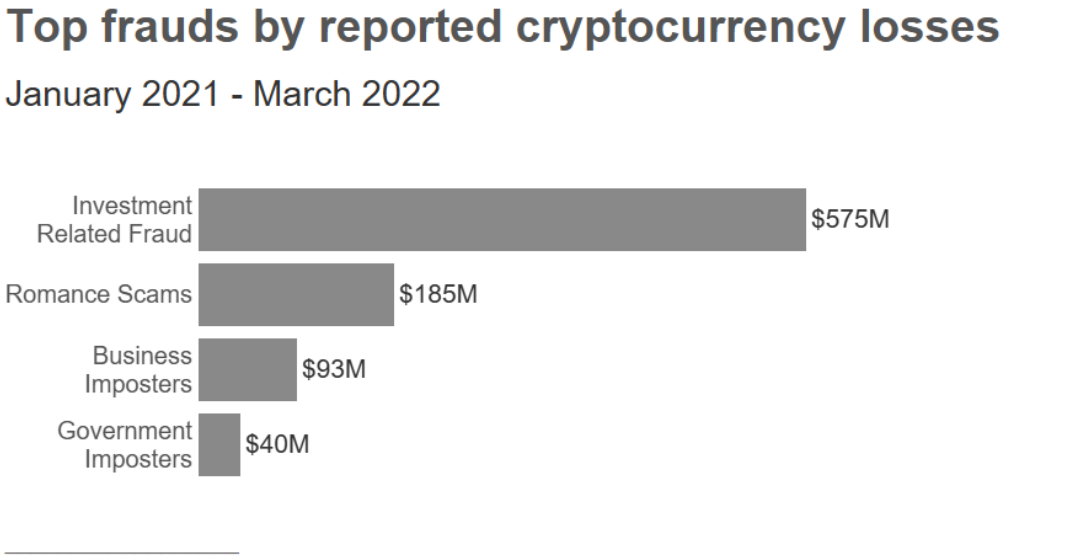
- How are keys stored?
  - Insecure key storage: Storing private keys in plaintext files, screenshots, or unprotected cloud backups makes them vulnerable to theft.
  - Cryptocurrency wallets: Software applications or hardware devices that securely manage private keys, create transactions, and generate digital signatures.

- Two major security threats arising from phishing or malware:
  - Private-key theft: An attacker steals Alice's private key and uses it to independently sign unauthorized transactions.
  - Malicious transaction signing: Alice retains control of her private key but is tricked into signing a transaction she did not intend to authorize.

Web3 Applications
(Takeaway)

- Web3 applications remain vulnerable to many traditional Web2 attacks because they still rely on browsers, websites, JavaScript, HTTP(S), APIs, and backend servers. Blockchain technology secures the underlying ledger but does not automatically secure the applications interacting with it.





Recent Cryptocurrency Frauds
(Incident 1)



cryptocurrency-based prediction market

October 29, 2026

- An attacker compromised a third-party performance-monitoring script loaded by Polymarket's website.
- The malicious JavaScript exploited active user sessions to sell positions and withdraw funds.
- Polymarket reported reimbursing affected traders.
- Loss: Approximately $2.7 million
- Type of Attack: Attack on Client, Session Hijacking, XSS style attack

Recent Cryptocurrency Frauds
(Incident 2)



February 21, 2025

- Bybit used a multisignature Ethereum cold wallet, managed through the Safe web application. Multiple authorized signers had to approve a transaction before the wallet's smart contract would execute it. This was designed to prevent one compromised private key from being sufficient to steal funds.
- Attackers compromised infrastructure used to serve the Safe web interface and injected malicious JavaScript. When Bybit's operators attempted to approve a legitimate cryptocurrency transfer, the malicious interface caused them to authorize a different transaction that transferred control of the wallet's smart contract to the attackers.
- Loss: theft of approximately $1.5 billion in Ethereum
- Type of Attack: Attack on server, XSS style attack (but not traditional XSS) called javascript supply-chain attack

Recent Cryptocurrency Frauds
(Incident 3)



February 21, 2025

- Drift Protocol is a decentralized trading platform built on the Solana blockchain. Users can deposit cryptocurrency, borrow assets, and trade leveraged positions.
- Drift has a Security Council, which controls sensitive administrative operations. These permissions were protected by a 2-of-5 multisignature arrangement: at least two of five authorized signers had to approve certain operations.
- Attackers tricked two administrators into signing transactions that transferred administrative control to the attackers. With this control, the attackers could change the platform's rules, including allowing a nearly worthless cryptocurrency to serve as valuable collateral.
- According to investigations, the attackers spent months posing as representatives of a quantitative trading firm and cultivating relationships with contributors.
- Loss: $285–296 million in cryptocurrency.
- Type of Attack: social engineering attack